



Weekly IT Security Brief (Official-source-first) | 2026-05-24 06:03

Formatted for readability · Auto-generated



Weekly Summary

- Priority snapshot: 8 KEV-listed vulnerabilities are actively exploited in the wild (top 8 shown in this brief).
- Urgent patch focus: CVE-2026-9082(2026-05-27), CVE-2025-34291(2026-06-04), CVE-2026-34926(2026-06-04). Prioritize internet-facing and privileged systems first.
- Threat trend #1: Microsoft recognized as a Leader in The Forrester Wave™ for Workforce Identity Security Platforms. Identity signals are captured in one pl Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous log...
- Threat trend #2: From edge appliance to enterprise compromise: Multi-stage Linux intrusion via F5 and Confluence. Tags Credential theft Linux Content types Research Products and services Microsoft Defender Topics Actionable threat insights Detection and prote...
- Recommended action this week: patch KEV/high-risk exposed services within 24 hours and tighten monitoring for anomalous login, command execution, and credential access patterns.



Report A: CVE Deep Dive (CISA KEV + NVD)

CVE-2026-9082

CVE Title	CVE-2026-9082 待核實 SQL Injection
CVE Description	Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection') vulnerability in Drupal Drupal core allows SQL Injection.
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	待核實
Risk Score	6.5 (MEDIUM)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-05-27
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-9082

CVE-2025-34291

CVE Title	CVE-2025-34291 langflow/langflow Remote Code Execution
CVE Description	Langflow versions up to and including 1.6.9 contain a chained vulnerability that enables account takeover and remote code execution. An overly permissive CORS configuration (allow_origins='*' with allow_credentials=True) combined with a refresh token cookie configured as SameSite=None allows a malicious webpage to perform cross-origin requests that include credentials and successfully call the refresh endp...
Root Cause	Unsafe deserialization or input-handling flaws enable arbitrary code execution.
Exploitation Prerequisite	Relevant endpoint is exposed and unpatched.
Exploit Path	Malicious request/payload -> vulnerability trigger -> remote command execution.
Affected Products	langflow/langflow
Risk Score	8.8 (HIGH)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-06-04
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2025-34291

CVE-2026-34926

CVE Title	CVE-2026-34926 待核實 Unknown Type
CVE Description	A directory traversal vulnerability in the Apex One (on-premise) server could allow a pre-authenticated local attacker to modify a key table on the server to inject malicious code to deploy to agents on affected installations.
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	待核實
Risk Score	6.7 (MEDIUM)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-06-04
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-34926

CVE-2008-4250

CVE Title	CVE-2008-4250 microsoft/windows_2000 Unknown Type
CVE Description	The Server service in Microsoft Windows 2000 SP4, XP SP2 and SP3, Server 2003 SP1 and SP2, Vista Gold and SP1, Server 2008, and 7 Pre-Beta allows remote attackers to execute arbitrary code via a crafted RPC request that triggers the overflow during path canonicalization, as exploited in the wild by Gimmiv.A in October 2008, aka "Server Service Vulnerability."
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	microsoft/windows_2000, microsoft/windows_server_2003, microsoft/windows_server_2008, microsoft/windows_vista, microsoft/windows_xp
Risk Score	9.8 (CRITICAL)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-06-03
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2008-4250

CVE-2009-1537

CVE Title	CVE-2009-1537 microsoft/directx Unknown Type
CVE Description	Unspecified vulnerability in the QuickTime Movie Parser Filter in quartz.dll in DirectShow in Microsoft DirectX 7.0 through 9.0c on Windows 2000 SP4, Windows XP SP2 and SP3, and Windows Server 2003 SP2 allows remote attackers to execute arbitrary code via a crafted QuickTime media file, as exploited in the wild in May 2009, aka "DirectX NULL Byte Overwrite Vulnerability."
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	microsoft/directx, microsoft/windows_2000, microsoft/windows_2003_server, microsoft/windows_server_2003, microsoft/windows_xp
Risk Score	8.8 (HIGH)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-06-03
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2009-1537

CVE-2009-3459

CVE Title	CVE-2009-3459 adobe/acrobat Buffer Overflow
CVE Description	Heap-based buffer overflow in Adobe Reader and Acrobat 7.x before 7.1.4, 8.x before 8.1.7, and 9.x before 9.2 allows remote attackers to execute arbitrary code via a crafted PDF file that triggers memory corruption, as exploited in the wild in October 2009. NOTE: some of these details are obtained from third party information.
Root Cause	Memory-safety weakness can cause memory corruption or unintended control flow.
Exploitation Prerequisite	Victim must process malicious content (web page/file/packet).
Exploit Path	Delivery of malicious content -> memory fault trigger -> code execution / crash.
Affected Products	adobe/acrobat, adobe/acrobat_reader
Risk Score	8.8 (HIGH)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-06-03
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2009-3459

CVE-2010-0249

CVE Title	CVE-2010-0249 microsoft/internet_explorer Use-After-Free
CVE Description	Use-after-free vulnerability in Microsoft Internet Explorer 6, 6 SP1, 7, and 8 on Windows 2000 SP4; Windows XP SP2 and SP3; Windows Server 2003 SP2; Windows Vista Gold, SP1, and SP2; Windows Server 2008 Gold, SP2, and R2; and Windows 7 allows remote attackers to execute arbitrary code by accessing a pointer associated with a deleted object, related to incorrectly initialized memory and improper handling of objects i...
Root Cause	Memory-safety weakness can cause memory corruption or unintended control flow.
Exploitation Prerequisite	Victim must process malicious content (web page/file/packet).
Exploit Path	Delivery of malicious content -> memory fault trigger -> code execution / crash.
Affected Products	microsoft/internet_explorer, microsoft/windows_2000, microsoft/windows_server_2003, microsoft/windows_xp, microsoft/windows_server_2008
Risk Score	8.8 (HIGH)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-06-03
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2010-0249

CVE-2010-0806

CVE Title	CVE-2010-0806 microsoft/internet_explorer Use-After-Free
CVE Description	Use-after-free vulnerability in the Peer Objects component (aka iepeers.dll) in Microsoft Internet Explorer 6, 6 SP1, and 7 allows remote attackers to execute arbitrary code via vectors involving access to an invalid pointer after the deletion of an object, as exploited in the wild in March 2010, aka "Uninitialized Memory Corruption Vulnerability."
Root Cause	Memory-safety weakness can cause memory corruption or unintended control flow.
Exploitation Prerequisite	Victim must process malicious content (web page/file/packet).
Exploit Path	Delivery of malicious content -> memory fault trigger -> code execution / crash.
Affected Products	microsoft/internet_explorer, microsoft/windows_2000, microsoft/windows_7, microsoft/windows_server_2003, microsoft/windows_server_2008
Risk Score	8.8 (HIGH)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-06-03
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2010-0806



Report A2: Newly Published CVEs (NVD, last 7 days)

CVE-2026-46728

CVE Title	CVE-2026-46728 待核實 Unknown Type
CVE Description	Das U-Boot before 2026.04 allows FIT (Flat Image Tree) signature verification bypass because hashed-nodes is omitted from a hash.
Affected Products	待核實
Risk Score	8.2 (HIGH)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-46728

CVE-2026-6050

CVE Title	CVE-2026-6050 待核實 Unknown Type
CVE Description	Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
Affected Products	待核實
Risk Score	待核實 (待核實)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-6050

CVE-2026-8723

CVE Title	CVE-2026-8723 待核實 Unknown Type
CVE Description	### Summary
Affected Products	待核實
Risk Score	5.3 (MEDIUM)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-8723

CVE-2026-8724

CVE Title	CVE-2026-8724 dataease/dataease SQL Injection
CVE Description	A security flaw has been discovered in Dataease 2.10.20. Impacted is the function SqlparserUtils.transFilter of the file SqlparserUtils.java of the component Data Dashboard. The manipulation results in sql injection. The attack may be launched remotely. The exploit has been released to the public and may be used for attacks. The vendor was contacted early about this disclosure.
Affected Products	dataease/dataease
Risk Score	4.7 (MEDIUM)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-8724

CVE-2026-8725

CVE Title	CVE-2026-8725 待核實 SSRF
CVE Description	A weakness has been identified in CoreWorxLab CAAL up to 1.6.0. The affected element is an unknown function of the file src/caal/webhooks.py of the component test-hass Endpoint. This manipulation causes server-side request forgery. Remote exploitation of the attack is possible. The exploit has been made available to the public and could be used for attacks. The vendor was contacted early about this disclosure but di...
Affected Products	待核實
Risk Score	7.3 (HIGH)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-8725

CVE-2026-8719

CVE Title	CVE-2026-8719 待核實 Privilege Escalation
CVE Description	The AI Engine – The Chatbot, AI Framework & MCP for WordPress plugin for WordPress is vulnerable to Privilege Escalation in version 3.4.9. This is due to missing WordPress capability enforcement in the MCP OAuth bearer-token authorization path, where any valid OAuth token causes MCP access to be granted without verifying administrator privileges. This makes it possible for authenticated (Subscriber+) attackers t...
Affected Products	待核實
Risk Score	8.8 (HIGH)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-8719



Report B: Threat Intelligence News (last 7 days)

Headline: Microsoft recognized as a Leader in The Forrester Wave™ for Workforce Identity Security Platforms

Source	Microsoft Security Blog
Published	Fri, 22 May 2026 17:00:00 +0000
Key Takeaway	Identity signals are captured in one pl Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	ot/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.microsoft.com/en-us/security/blog/2026/05/22/microsoft-recognized-as-a-leader-in-the-forrester-wave-for-workforce-identity-security-platforms/

Headline: From edge appliance to enterprise compromise: Multi-stage Linux intrusion via F5 and Confluence	
Source	Microsoft Security Blog
Published	Fri, 22 May 2026 16:53:39 +0000
Key Takeaway	Tags Credential theft Linux Content types Research Products and services Microsoft Defender Topics Actionable threat insights Detection and protection success stories In this article Attack chain overview Initial access: Exploiting edge appliances Discovery and reconnaissance Lateral movement and id Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral mov...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	ot/待核實
Technique	Credential Access
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.microsoft.com/en-us/security/blog/2026/05/22/from-edge-appliance-to-enterprise-compromise-multi-stage-linux-intrusion-via-f5-and-confluence/

Headline: CISA Enhances Known Exploited Vulnerabilities Catalog to Include New Nomination Form

Source	CISA News
Published	Thu, 21 May 26 12:00:00 +0000
Key Takeaway	CISA Enhances Known Exploited Vulnerabilities Catalog to Include New Nomination Form
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	Exploit Chain
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.cisa.gov/news-events/news/cisa-enhances-known-exploited-vulnerabilities-catalog-include-new-nomination-form

Headline: CISA Unveils New Initiative to Fortify America’s Critical Infrastructure

Source	CISA News
Published	Tue, 05 May 26 12:00:00 +0000
Key Takeaway	CISA Unveils New Initiative to Fortify America’s Critical Infrastructure
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	critical infrastructure/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.cisa.gov/news-events/news/cisa-unveils-new-initiative-fortify-americas-critical-infrastructure

Headline: Welcome to BlackFile: Inside a Vishing Extortion Operation

Source	Mandiant Blog
Published	Fri, 15 May 2026 14:00:00 +0000
Key Takeaway	Written by: Austin Larsen, Tyler McLellan, Genevieve Stark, Dan Ebreo Introduction Google Threat Intelligence Group (GTIG) has continued to track an expansive extortion campaign by UNC6671, a threat actor operating under the "BlackFile" brand, that targets organizations via sophisticated voice phish Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/l...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	defense/north america
Technique	Social Engineering
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://cloud.google.com/blog/topics/threat-intelligence/blackfile-vishing-extortion-operation/

Headline: GTIG AI Threat Tracker: Adversaries Leverage AI for Vulnerability Exploitation, Augmented Operations, and Initial Access

Source	Mandiant Blog
Published	Mon, 11 May 2026 14:00:00 +0000
Key Takeaway	We explore the following developments: Vulnerability Discovery and Exploit Generation: For the first time, GTIG has identified a threat actor using a zero-day exploit that we believe was developed with AI. The criminal threat actor planned to use it in a mass exploitation event but our proactive cou Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral mov...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	government/asia
Technique	T0008.000,T0008.005,T0010.001
MITRE ATT&CK	T0008.000, T0008.005, T0010.001, T0016.001, T0016.002, T0021, T0040, T0054, T0072, T0088, T0102, T0103, T1027.014, T1027.016, T1090.003, T1566, T1587.001, T1587.004, T1588.002, T1588.005, T1588.006, T1588.007, T1591.002, T1591.004, T1592.001
Related CVEs	None
Link	https://cloud.google.com/blog/topics/threat-intelligence/ai-vulnerability-exploitation-initial-access/

Headline: The art of being ungovernable

Source Cisco Talos Blog

Published Thu, 21 May 2026 18:00:14 GMT

Key Takeaway The art of being ungovernable Blog Intelligence Center Intelligence Center BACK Intelligence Search Email & Spam Trends Vulnerability Research Vulnerability Research BACK Vulnerability Reports Microsoft Advisories Incident Response Incident Response BACK Reactive Services Proactive Services Emergenc Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral...

Summary Engine extractive-rules

Threat Actors Not explicitly stated

Target unknown-target

Technique 待核實

MITRE ATT&CK Unverified

Related CVEs None

Link <https://blog.talosintelligence.com/the-art-of-being-ungovernable/>

Headline: TP-Link, Photoshop, OpenVPN, Norton VPN vulnerabilities

Source	Cisco Talos Blog
Published	Tue, 19 May 2026 15:39:37 GMT
Key Takeaway	Cisco Talos' Vulnerability Discovery & Research team recently disclosed eight vulnerabilities in TP-Link, and one each in Adobe Photoshop, OpenVPN, and Gen Digital's Norton VPN. The vulnerabilities mentioned in this blog post have been patched by their respective vendors, in adherence to Cisco's thi Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/la...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	ot/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://blog.talosintelligence.com/tp-link-photoshop-openvpn-norton-vpn-vulnerabilities/

Headline: npm Adds 2FA-Gated Publishing and Package Install Controls Against Supply Chain Attacks

Source	The Hacker News
Published	Sat, 23 May 2026 22:05:10 +0530
Key Takeaway	GitHub has rolled out new controls for npm to improve the security of the software supply chain, giving maintainers the ability to explicitly approve a release prior to the packages becoming publicly available for installation. Called staged publishing, the feature is now generally available on npm. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral mov...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://thehackernews.com/2026/05/npm-adds-2fa-gated-publishing-and.html

Headline: Packagist Supply Chain Attack Infects 8 Packages Using GitHub-Hosted Linux Malware

Source	The Hacker News
Published	Sat, 23 May 2026 21:37:51 +0530
Key Takeaway	A new "coordinated" supply chain attack campaign has impacted eight packages on Packagist including malicious code designed to run a Linux binary retrieved from a GitHub Releases URL. "Although the affected packages were all Composer packages, the malicious code was not added to composer.json," Sock Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalou...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	ot/待核實
Technique	Malware Deployment
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://thehackernews.com/2026/05/packagist-supply-chain-attack-infects-8.html

Headline: 'Underminr' Vulnerability Lets Attackers Hide Malicious Connections Behind Trusted Domains

Source	SecurityWeek
Published	Sat, 23 May 2026 11:00:00 +0000
Key Takeaway	The stealthy vulnerability impacts roughly 88 million domains and can be exploited to bypass DNS filtering and hide command-and-control traffic. The post 'Underminr' Vulnerability Lets Attackers Hide Malicious Connections Behind Trusted Domains appeared first on SecurityWeek . Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	Exploit Chain
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.securityweek.com/underminr-vulnerability-lets-attackers-hide-malicious-connections-behind-trusted-domains/

Headline: Drupal Vulnerability in Hacker Crosshairs Shortly After Disclosure

Source	SecurityWeek
Published	Fri, 22 May 2026 17:15:26 +0000
Key Takeaway	Drupal is warning users that it has already seen attempts to exploit CVE-2026-9082 and security firms are seeing attacks against thousands of websites. The post Drupal Vulnerability in Hacker Crosshairs Shortly After Disclosure appeared first on SecurityWeek . Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	Exploit Chain
MITRE ATT&CK	Unverified
Related CVEs	CVE-2026-9082
Link	https://www.securityweek.com/drupal-vulnerability-in-hacker-crosshairs-shortly-after-disclosure/



Sources (official/authoritative first)

<https://www.cisa.gov/known-exploited-vulnerabilities-catalog>

<https://nvd.nist.gov/>

<https://www.cve.org/>

<https://attack.mitre.org/>

[**https://www.microsoft.com/en-us/security/blog/**](https://www.microsoft.com/en-us/security/blog/)

[**https://www.cisa.gov/news-events/cybersecurity-advisories**](https://www.cisa.gov/news-events/cybersecurity-advisories)

[**https://www.mandiant.com/resources**](https://www.mandiant.com/resources)

[**https://blog.talosintelligence.com/**](https://blog.talosintelligence.com/)